Information Security Policy

Fictional sample document for this PoC; not a real policy.

1. Purpose and information ownership

The company protects business and customer information wherever employees work. This fictional policy applies to employees, temporary staff, and contractors with company system access. Information Security owns the policy; IT operates managed devices and access services. Each team has an information owner responsible for deciding who needs access to its working material. Access should be limited to the minimum required for current duties and removed when those duties change.

Company information is classified as Public, Internal, or Restricted. Public material has been approved for external release. Internal material is intended for staff and approved collaborators. Restricted material includes customer records, unreleased financial results, and authentication secrets. When a classification is unclear, treat the material as Internal and ask its owner before sharing it outside the company. A document being easy to access does not imply permission to publish it.

2. Accounts and access

2.1 Authentication

Company passwords must contain at least 14 characters, and multi-factor authentication is required for all company accounts that support it. Employees must use the company-approved password manager and must not reuse a company password on a personal service.

Never send a password, recovery code, or multi-factor prompt approval to another person, including someone claiming to work for IT. IT verifies identity through the service desk process and does not request an employee's password. Report unexpected authentication prompts promptly using the incident procedure. Shared accounts require a documented business exception from Information Security, an identified owner, and a recorded review date. An exception must not be used to avoid keeping individual accountability where individual accounts are available.

2.2 Access reviews

Line managers review their teams' system access every quarter and notify IT within two working days when access is no longer needed. IT disables accounts by the recorded departure time when People Operations confirms an employee's exit.

A change of role requires a review of existing access as well as any request for new access. Employees may not retain permissions merely because they held them in an earlier role. Temporary access must include an expiry date in the request. Information owners approve access to Restricted material; a line manager's approval alone is insufficient when the manager does not own the information.

3. Devices and remote work

3.1 Managed devices

Company work must be performed on IT-managed devices with disk encryption and automatic screen locking enabled. Lock the screen whenever leaving a device unattended, even briefly in a shared home workspace.

IT deploys critical security updates within 7 calendar days of release after checking compatibility. Employees should restart their device when prompted and report repeated update failures to the service desk. Personal storage drives and unapproved cloud services must not hold company information. The Remote Work Policy covers workspace suitability and the supply of a managed laptop; an equipment reimbursement does not make a personal device approved for company data.

3.2 Remote access

Use the company VPN when accessing internal systems outside the office. Do not bypass access controls or disable security software to make a connection work; contact IT for help instead.

Avoid using public charging stations that require a data connection to the laptop. Keep devices in personal custody while travelling and use a privacy screen when confidential work in a shared location cannot be avoided. Before overseas business travel, contact Information Security to check any restrictions on devices or information. Approval of a travel expense does not authorise unrestricted access from another country.

4. Incidents and retention

4.1 Incident reporting

Report a lost device, suspected phishing, or accidental disclosure to the Information Security duty contact within 1 hour of discovery. Use the security incident form or telephone the service desk if the form is unavailable.

Record when the incident was discovered, the affected device or service, and the actions already taken. Do not delete suspicious messages or investigate another person's account yourself. Information Security coordinates containment and tells employees how to preserve evidence. Employees should report uncertain events promptly rather than waiting to prove a breach; an honest report made in good faith will not itself result in disciplinary action.

4.2 Retention and disposal

Store Restricted records only in repositories approved by their information owner. When the documented retention period ends, use the repository's approved deletion process instead of moving the files into personal archives.

Records subject to a written investigation hold must be preserved until the hold is released. Employees should ask the information owner when a record lacks a retention instruction. IT arranges secure disposal of company storage devices; staff must not sell, donate, or discard those devices themselves. Information Security reviews this policy annually and records material changes in the staff policy register.